

DEVSECOPS LAB BOOK

Chapter 37

Advanced Zero Trust Architecture

Trust nobody. Verify everything. Design for breach.

Next-Generation Security | Identity · Data · Network · Devices · Workloads

Zero Trust Principles

Why the old perimeter model breaks down — and what replaces it

Traditional Model

Trust the network (perimeter security)

- Breach inside perimeter = full access
- Lateral movement is easy
- No micro-segmentation
- Difficult to detect internal threats

Zero Trust Model

Trust nobody, verify everything

- Every access authenticated & authorized
- Encryption everywhere (in transit & at rest)
- Continuous monitoring
- Micro-segmentation
- Least privilege access

Implementation Layers

Five layers where Zero Trust controls must be enforced

1



Identity & Access

- MFA everywhere
- Continuous device posture checks
- Risk-based access decisions
- Teleport for all SSH access

2



Data

- Encrypt in transit (TLS everywhere)
- Encrypt at rest (Vault)
- Data classification
- DLP (Data Loss Prevention)

3



Network

- Microsegmentation per app
- Network policies enforced
- Encrypted service-to-service (mTLS)
- No implicit trust between services

4



Devices

- Hardware security modules (HSM)
- Full disk encryption
- Endpoint Detection & Response
- Vulnerability scanning

5



Workloads

- Container security scanning
- Immutable infrastructure
- Runtime security enforcement
- Behavioral analysis

Kubernetes Zero Trust

A complete reference setup — five controls, layered together



Pod Security Standards

Non-root, no privilege escalation, all capabilities dropped, read-only root filesystem

`PodSecurityPolicy`



Default-Deny Network Policy

Blocks all ingress & egress by default; access must be explicitly allowed

`NetworkPolicy`



RBAC — Least Privilege

Roles scoped to only the verbs and resources a workload actually needs

`Role`



Istio Authorization

Service-to-service rules by identity (principal), method, and path

`AuthorizationPolicy`



Secrets Encryption

aescbc provider encrypts Secret resources at rest in etcd

`EncryptionConfiguration`

Zero Trust Metrics

Tracking Zero Trust implementation — targets, measures, and goals

100%

Monthly Access Reviews

Target: weekly reviews · Goal: 100% users reviewed monthly

100%

MFA Adoption

Measure: users with MFA enabled · Goal: complete within 30 days

99%+

Encryption Coverage

Measure: % of traffic encrypted · Target: 100% of data

0

Segmentation Violations

Measure: network policy violations · Goal: zero violations

1000+

Verification Checks / Hour

Target: real-time, continuous verification



Key Takeaways

- Zero Trust replaces implicit network trust with continuous verification at every layer
- Five layers — identity, data, network, devices, workloads — must work together, not in isolation
- Kubernetes gives concrete primitives: PSPs, default-deny NetworkPolicies, RBAC, Istio AuthorizationPolicy, Secrets encryption
- Track adoption with hard metrics: MFA %, encryption coverage, segmentation violations, verification rate